PHYSIOTHERAPY CLINIC

# Management System

Full System Requirements, Functional Specification, Workflow & Implementation Documentation

**Document purpose**
A complete implementation guide for designing and building a clean, simple clinic management application focused on patient records, clinical visits, configurable physiotherapy services, expenses, and operational reporting.

**Product direction**
Keep the day-to-day experience simple for clinic staff while allowing the Administrator to configure services, prices, categories, fields, clinic details, workflows, and other operational settings without changing source code.

| Document control | Value |
|---|---|
| Document type | Software Requirements & System Design Specification |
| Version | 1.0 |
| Prepared | 12 November 2026 |
| Intended audience | Clinic owner/management, clinic representative, developers, testers and system administrator |
| Status | Implementation baseline – confirm clinic-specific policies before production |

CONFIDENTIAL – PROJECT IMPLEMENTATION DOCUMENT

# Document Contents


- 1. Executive Summary
- 2. Vision, Goals and Design Principles
- 3. Scope and Boundaries
- 4. Users, Roles and Permission Model
- 5. System Navigation and Main Modules
- 6. Detailed Functional Requirements
- 7. Configurable Administration and Clinic Setup
- 8. End-to-End System Workflows
- 9. Business Rules and Validation
- 10. Data Model and Database Structure
- 11. Reports, Dashboards and Exports
- 12. Security, Privacy and Auditability
- 13. User Interface and Experience Requirements
- 14. Technical Architecture and Recommended Stack
- 15. API and Integration Design
- 16. Non-Functional Requirements
- 17. Backup, Deployment and Operations
- 18. Testing and Acceptance Criteria
- 19. Implementation Phases and Deliverables
- 20. Risks, Assumptions and Decisions to Confirm
- Appendix A – Suggested Screen Inventory
- Appendix B – Example Configuration Catalogue
- Appendix C – Glossary


**This specification defines a deliberately lightweight system. Optional capabilities are included as configurable extensions, not as mandatory complexity in the daily workflow.**

# 1. Executive Summary

The Physiotherapy Clinic Management System (PCMS) is a small, secure, browser-based application for a physiotherapy clinic. Its primary purpose is to maintain reliable patient records, record each patient visit and treatment session, manage the services offered by the clinic, capture operating expenses, and provide useful summaries to management.

The system is not intended to become a full hospital information system. It should avoid unnecessary departments, complex billing, pharmacy, laboratory, payroll, insurance claims, and inpatient workflows unless the clinic later approves them as separate enhancements.

A key requirement is configurability: the Administrator must be able to manage the clinic's service catalogue and operational settings through the interface. Adding a new service, changing a service description, activating/deactivating a service, adjusting its standard price, or changing expense categories should not require a developer or source-code edit.

The initial user model has two fixed roles: **Administrator** and **Clinic Staff**. These role identifiers and their core permission boundaries are hardcoded. The Administrator manages users and configuration; Clinic Staff perform approved daily operations. The Administrator may configure data and workflow settings, but cannot grant Clinic Staff access to protected administrative functions.

## 1.1 Expected outcomes

- One central patient register with a unique patient number and searchable patient profiles.
- A visit history for each patient, including symptoms/complaints, assessment notes, selected services, treatment notes and follow-up guidance.
- A configurable catalogue of physiotherapy services provided by the clinic.
- A simple expense register with categories, dates, amounts, attachments/receipts where enabled, and recorded-by information.
- Daily, weekly and monthly operational reports for patient activity, service usage and expenses.
- Clear accountability through user attribution and audit logs.
- A responsive, low-clutter interface suitable for desktop, tablet and mobile browsers.

## 1.2 Core product rule

**The daily workflow should require as few steps as possible: find or register a patient → open a visit → record the service and clinical notes → save → view or print the record. Expense recording should be similarly short: open expenses → add expense → choose category → enter amount/date → save.**

# 2. Vision, Goals and Design Principles

## 2.1 Vision

Provide a dependable digital record book for a physiotherapy clinic, replacing scattered paper registers and informal expense notes with a simple, searchable and accountable system.

## 2.2 Goals

- Reduce time spent searching for patient files.
- Keep a chronological record of patient visits and services provided.
- Give management visibility into patient volumes and clinic expenses.
- Allow the clinic to change its service offering and standard charges without code changes.
- Protect confidential patient information through role-based access and audit trails.
- Make the system easy for a non-technical clinic representative to operate.

### 2.3 Design principles

| Principle | Implementation meaning |
|---|---|
| Simple first | Show only the actions relevant to the current user; avoid complex navigation. |
| Configurable, not hardcoded | Service names, descriptions, prices, categories, clinic details and selected options are stored as data. |
| Fixed security boundaries | Only two fixed application roles in version 1: Administrator and Clinic Staff. |
| Traceable records | Every created or updated record stores the responsible user and timestamps. |
| Safe history | Clinical and financial history should be archived/voided with a reason rather than silently erased. |
| Mobile-friendly | Forms and tables must work on common phone and desktop screen sizes. |

# 3. Scope and Boundaries

## 3.1 Included in Version 1

- Authentication, password reset and user account management.
- Patient registration, profile management, search and patient history.
- Patient visits/sessions and clinical notes.
- Configurable physiotherapy service catalogue.
- Expense categories and expense records.
- Dashboard and standard reports with PDF/CSV export.
- Clinic settings, configurable numbering, currency, date format and selected form options.
- Audit logs, backups and basic system health/maintenance controls.

## 3.2 Not included in the initial release

- Pharmacy, drug dispensing and stock control.
- Laboratory orders and results.
- Hospital admission, beds, wards and inpatient management.
- Payroll, staff attendance and human resource management.
- Insurance claims and insurer integrations.
- Advanced accounting, tax filing, bank reconciliation or general ledger.
- Online patient portal, telemedicine or mobile apps.
- Automated diagnosis, clinical decision support or AI-generated treatment plans.

**These items may be considered later. They must not delay delivery of the core patient, visit, service and expense workflows.**

## 3.3 Optional features controlled by Administrator

Some optional capabilities may be enabled or disabled from Settings, such as receipt attachments, patient photo, emergency contact, service pricing display, visit reference numbers, PDF letterhead, and staff access to selected reports. Turning off an optional feature should hide it from new-entry forms without deleting historical data.

# 4. Users, Roles and Permission Model

## 4.1 Fixed roles

| Role | Purpose | Access summary |
|---|---|---|
| Administrator | Clinic owner or trusted system manager. | Full system access, user management, configuration, all patient/visit/expense records, reports, audit logs and backups. |
| Clinic Staff | Clinic representative who enters daily records. | Register and update patients, record visits and services, create expenses, and view permitted operational records. No user administration or system configuration. |

## 4.2 Permission matrix

| Capability | Administrator | Clinic Staff |
|---|---|---|
| Sign in / sign out | Yes | Yes |
| View dashboard | All metrics | Operational summary only |
| Register patient | Yes | Yes |
| Edit patient profile | Yes | Yes, subject to field restrictions |
| Archive patient | Yes | No |
| Create / edit visit | Yes | Yes |
| Void a visit | Yes, reason required | No |
| Manage service catalogue | Yes | No |
| Create expense | Yes | Yes |
| Edit own expense | Yes | Yes, if not locked |
| Edit any expense | Yes | No |
| Delete / void expense | Yes, reason required | No |
| Manage expense categories | Yes | No |
| View reports | All | Selected reports |
| Export reports | Yes | Only if enabled |
| Create / deactivate users | Yes | No |
| Clinic settings / configuration | Yes | No |
| Audit log | Yes | No |
| Backup / restore | Yes or authorised technical operator | No |

## 4.3 Hardcoded role implementation

Use fixed role keys such as ADMIN and CLINIC_STAFF. Do not build a role designer or allow users to create new role types in Version 1. Store the role key on each user and enforce authorization on the server for every protected route/action. Hiding a menu item is not sufficient security.

## 4.4 Account management

- Administrator can create staff accounts, assign the fixed Clinic Staff role, reset credentials and deactivate accounts.
- Each user must have a unique username or email and a secure password.

- Deactivated users cannot sign in; their historical records remain attributed to their user account.
- Do not share accounts. Each person must use their own login.
- Require password change on first login when the Administrator creates a temporary password.

# 5. System Navigation and Main Modules

| Main menu | Purpose | Primary actions |
|---|---|---|
| Dashboard | At-a-glance clinic activity. | View patient counts, visits, service activity and expense totals. |
| Patients | Patient master register. | Register, search, open profile, edit permitted details, view history. |
| Visits / Sessions | Clinical encounter register. | Create visit, record assessment and treatment, add service, save notes. |
| Services | Clinic service catalogue. | Admin adds, edits, prices, activates or deactivates services. |
| Expenses | Operating expense register. | Record, search, filter, review and export expenses. |
| Reports | Management summaries. | Filter by period, service, staff member and expense category. |
| Settings | Clinic configuration. | Manage clinic profile, options, categories, numbering, users and access. |
| Audit Log | Accountability and security history. | Review who performed sensitive actions and when. |

## 5.1 Suggested navigation

Sidebar: Dashboard | Patients | Visits | Services (Admin only) | Expenses | Reports | Settings (Admin only). The top bar should show clinic name, current user, role, notifications for system messages and sign-out. Avoid deep menu nesting.

# 6. Detailed Functional Requirements

## 6.1 Authentication

- FR-AUTH-01: The system shall provide a login screen using username/email and password.
- FR-AUTH-02: The system shall validate credentials on the server and establish a secure session.
- FR-AUTH-03: The system shall support logout and session expiry after an Administrator-configurable inactivity period.
- FR-AUTH-04: The system shall provide a password reset process controlled by the configured email method or by Administrator-assisted reset.
- FR-AUTH-05: Repeated failed login attempts shall be rate-limited and logged.

## 6.2 Patient management

Patient records are the central entity. A patient may have multiple visits over time. Patient registration should capture only necessary information; the Administrator can enable optional fields.

| Field | Required? | Notes |
|---|---|---|
| Patient number | System-generated | Unique, configurable prefix and sequence. |
| Full name | Yes | Allow normal local name formats. |
| Sex / gender | Configurable | Use the clinic's approved options; allow 'Prefer not to say' if appropriate. |
| Date of birth or age | At least one | Avoid storing both inconsistently; age can be calculated from DOB. |
| Phone number | Recommended | Validate Tanzania format but allow other country codes if configured. |
| Address / location | Optional | Region, district, ward or free-text address. |

| Field | Required? | Notes |
|---|---|---|
| Emergency contact | Optional | Name, relationship and phone. |
| Relevant medical history | Optional | Free text; collect only clinically relevant information. |
| Registration date | Automatic | System timestamp; editable only by Administrator with audit. |
| Status | Automatic | Active or archived. |

### Patient functions

- Create a patient and generate a unique patient number.
- Search by patient number, name or phone; search should be forgiving of spaces and case.
- Open a profile with demographic details and chronological visit history.
- Update patient details while retaining an audit trail.
- Prevent accidental duplicate registration by warning on matching phone/name/date of birth; allow authorised continuation where a duplicate is legitimate.
- Archive a patient instead of permanent deletion. Archived patients remain available in historical reports.

## 6.3 Visits and treatment sessions

A visit represents one attendance/encounter at the clinic. One patient can have many visits. A visit may include one or more configured services.

| Visit field | Description |
|---|---|
| Visit reference | System-generated unique reference. |
| Patient | Link to an existing patient. |
| Visit date/time | Defaults to current clinic time; authorised correction is audited. |
| Chief complaint | Patient's stated reason for attendance. |
| Assessment / findings | Clinical observations recorded by the responsible practitioner. |
| Service(s) provided | Select from active service catalogue; allow multiple services if configured. |
| Treatment notes | What was performed during this session. |
| Plan / advice | Follow-up advice or next-step notes. |
| Follow-up date | Optional date for suggested return. |
| Recorded by | Authenticated user, captured automatically. |
| Status | Draft, Completed, or Voided. |

### Visit rules

- A visit cannot be saved without a patient and visit date.
- At least one service may be required if the Administrator enables that rule.
- Clinical notes should be plain text or safe rich text with length limits.
- Only Administrator can void a completed visit; a reason is mandatory.
- Completed visits are read-only for Clinic Staff unless the Administrator enables a controlled correction window.
- Every correction to a completed visit must preserve the previous value in the audit history.

## 6.4 Configurable service catalogue

The services offered by the clinic must be managed from the Administrator interface. Service names and categories must never be embedded directly into application code or fixed dropdown lists.

| Service property | Admin control |
|---|---|
| Service name | Create, edit and rename. |
| Service code | Optional unique code; generated or manually entered. |
| Category | Create and manage categories such as rehabilitation or therapy. |
| Description | Editable service description. |
| Standard price | Set amount in clinic currency; may be zero or marked 'price not applicable'. |
| Duration | Optional estimated duration in minutes. |
| Active / inactive | Inactive services are hidden from new visits but remain on historical visits. |
| Display order | Set order in selection lists. |
| Requires notes | Optionally require treatment notes when this service is selected. |
| Available from / to | Optional effective dates for service availability or pricing. |

Examples only (the clinic must confirm its actual catalogue): Physiotherapy Assessment, Manual Therapy, Exercise Therapy, Electrotherapy, Neurological Rehabilitation, Paediatric Physiotherapy, Orthopaedic Rehabilitation, Sports Injury Rehabilitation, Occupational Therapy, Massage Therapy and Home-based Physiotherapy.

**The examples are not a mandatory fixed list. The Administrator can add any service, change the names, create categories, set prices, disable a service or reorder the list without developer assistance.**

## 6.5 Expense management

| Expense field | Description |
|---|---|
| Expense reference | System-generated unique number. |
| Title | Short description of the expense. |
| Category | Select from configurable active expense categories. |
| Amount | Positive amount in configured clinic currency. |
| Expense date | Date the expense occurred. |
| Description / notes | Optional explanation. |
| Supplier / payee | Optional person or business paid. |
| Payment method | Configurable options such as cash, bank or mobile money. |
| Receipt attachment | Optional image/PDF if enabled by Administrator. |
| Recorded by | Authenticated user, captured automatically. |
| Status | Submitted, Approved (optional workflow), or Voided. |

### Expense workflow options

For a very small clinic, use a simple mode: staff records an expense and it appears in the register. If the clinic wants approval control, Administrator can enable approval mode. In approval mode, staff-submitted expenses remain Submitted until Administrator approves or rejects them. Do not make approval mandatory unless the clinic requests it.

### Expense category configuration

Administrator can add, rename, reorder, activate or deactivate categories (for example: Medical Supplies, Equipment Maintenance, Electricity, Water, Rent, Transport, Staff Welfare and Other). These are examples only. Historical expenses retain the category label/code used when they were recorded.

## 6.6 Dashboard

- Show total registered active patients.
- Show patients registered during the selected period.
- Show visits today and this month.
- Show expenses today and this month.
- Show expense breakdown by category.
- Show recent patients, recent visits and recent expenses according to the user's permissions.
- Provide date filters and avoid presenting financial or clinical details to unauthorised roles.

## 6.7 Reports

- Patient register report: patient number, name, contact and registration date.
- Patient registration report: daily, weekly, monthly and custom date range.
- Visit report: visits by date, service, staff member and status.
- Patient history report: profile and chronological visits, subject to access permissions.
- Service usage report: number of visits per service and period.
- Expense report: date, reference, category, title, amount, recorded by and status.
- Expense summary: total by category and date period.
- Export reports to PDF and CSV; Excel export may be added if required.
- All reports must display the selected date range, generation time and generating user.

# 7. Configurable Administration and Clinic Setup

The system must separate fixed security rules from configurable clinic data. The Administrator should be able to manage routine clinic changes through Settings without developer intervention.

## 7.1 Settings groups

| Settings group | Configurable items |
|---|---|
| Clinic profile | Clinic name, logo, address, phone, email, registration details, report footer and letterhead. |
| Regional settings | Currency (default TZS), timezone (default Africa/Dar_es_Salaam), date format and number format. |
| Patient settings | Patient number prefix, sequence, optional fields, duplicate warning rules and archive policy. |
| Visit settings | Visit reference prefix, required fields, multiple services per visit, note requirements and correction window. |
| Service settings | Service categories, services, descriptions, prices, durations, active status and display order. |
| Expense settings | Expense categories, payment methods, attachment option, approval mode and expense reference prefix. |
| Reports | Default date range, logo, signature lines, footer text and permitted exports. |
| User settings | Create/deactivate users, password reset, session timeout and access to selected reports. |
| Notifications | Optional email/SMS settings and notification templates if integrations are later enabled. |
| Data and retention | Archive options, backup schedule display and retention policy configuration. |

### 7.2 Configuration governance

- Only Administrator can access Settings.
- Configuration changes must be validated and logged with old value, new value, user and timestamp.
- Do not allow changing a service or category in a way that rewrites historical transactions.
- Deactivating a service/category must not remove it from old visits/expenses.
- Critical settings such as currency or timezone should require confirmation and display a warning about historical reporting effects.
- Where possible, store configuration in database tables rather than environment variables. Environment variables are reserved for secrets and deployment-level settings.

### 7.3 Hardcoded versus configurable

| Hardcoded in application | Configurable by Administrator |
|---|---|
| ADMIN and CLINIC_STAFF role keys. | Clinic name, address, logo and contact details. |
| Authorization enforcement and protected actions. | Service catalogue, categories, prices and durations. |
| Core data integrity rules and audit mechanism. | Expense categories and payment methods. |
| Password hashing and security controls. | Patient/visit/expense numbering prefixes. |
| Core module structure and database relationships. | Optional fields, approval mode and report presentation. |
| System permission boundaries. | Timezone, date format and session timeout within safe limits. |

## 8. End-to-End System Workflows

### 8.1 Login and role routing

1. User opens the system URL. 2. User enters credentials. 3. Server validates the account and status. 4. System creates a secure session. 5. System loads the user's fixed role. 6. Dashboard and navigation are filtered by permissions. 7. Every request is re-authorised on the server.

### 8.2 New patient registration

1. Staff selects Patients → Add Patient. 2. Staff enters required patient details. 3. System checks for possible duplicates. 4. Staff confirms or cancels. 5. System generates patient number. 6. Patient record is saved with created_by and timestamps. 7. System displays the patient profile and offers 'Create Visit'.

### 8.3 Returning patient visit

1. Staff searches by patient number, name or phone. 2. Staff opens the correct patient profile. 3. Staff selects 'New Visit'. 4. System creates a draft visit with date/time and user. 5. Staff records complaint and assessment. 6. Staff selects one or more active services. 7. Staff records treatment notes and plan. 8. Staff saves or completes the visit. 9. System adds the visit to patient history and audit log.

### 8.4 Add or change clinic service

1. Administrator opens Settings → Services. 2. Administrator selects Add Service or edits an existing service. 3. Administrator enters name, category, description, optional price/duration and status. 4. System validates unique code/name rules. 5. Administrator saves. 6. Service becomes available in new visits if active. 7. Existing visits remain unchanged.

## 8.5 Record an expense

1. Staff opens Expenses → Add Expense. 2. Staff enters title, category, amount and date. 3. Staff optionally adds description, payee and receipt. 4. System validates amount/category/date. 5. Staff saves. 6. In simple mode, expense is recorded immediately; in approval mode, it is marked Submitted. 7. System stores recorded_by and creates an audit event.

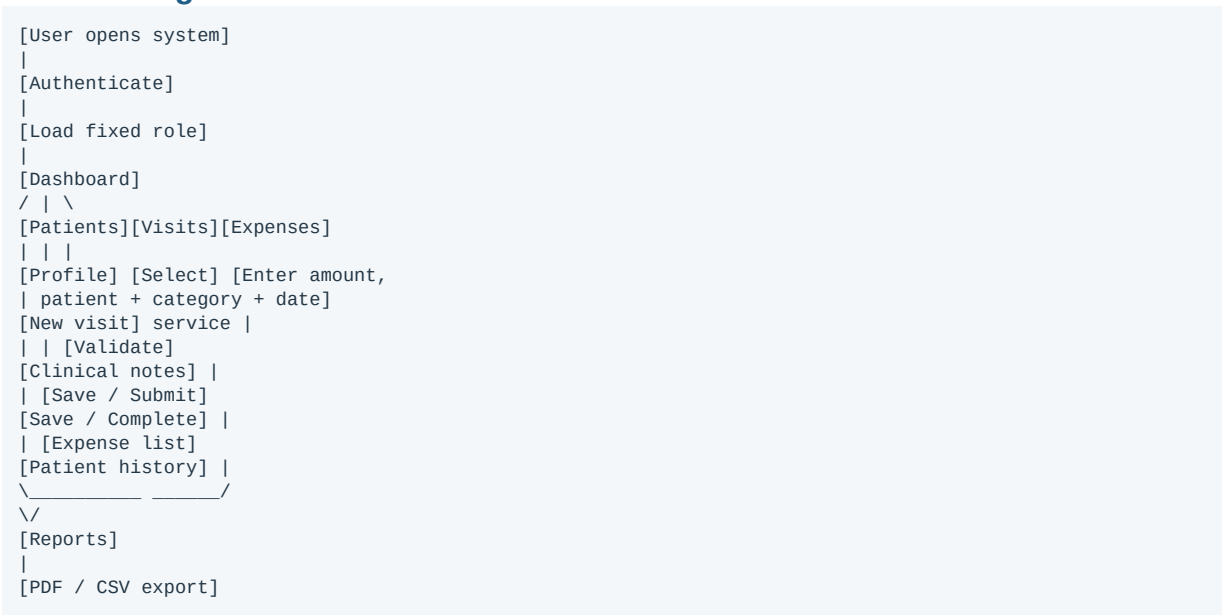
## 8.6 Expense approval (optional)

1. Administrator opens Pending Expenses. 2. Administrator reviews details and attachment. 3. Administrator approves or rejects with a reason. 4. System records reviewer, decision and timestamp. 5. Approved expenses are included in approved-expense totals; rejected/voided expenses are excluded from those totals but remain visible in history.

## 8.7 Reporting

1. User opens Reports. 2. User selects report type and date range. 3. System applies role-based data access and filters. 4. User previews totals and rows. 5. User exports PDF/CSV if permitted. 6. System records export event where appropriate.

## 8.8 Workflow diagram



# 9. Business Rules and Validation

| ID | Rule |
|---|---|
| BR-01 | Every patient must have a unique system patient number. |
| BR-02 | A patient may have multiple visits; each visit belongs to exactly one patient. |
| BR-03 | A visit may contain one or more services according to the configured rule. |
| BR-04 | Only active services may be selected for new visits. |
| BR-05 | Historical visits retain a snapshot of service name/code and applicable price at the time of the visit. |
| BR-06 | Expense amount must be greater than zero and use the configured currency. |
| BR-07 | Every expense must have a category, expense date and recorded_by user. |
| BR-08 | Clinic Staff cannot access administration or modify system configuration. |
| BR-09 | Sensitive void/archive actions require a reason and are audit logged. |
| BR-10 | Records with historical links should be archived/voided rather than physically deleted. |
| BR-11 | Reports must apply date filters consistently using the configured clinic timezone. |
| BR-12 | Deactivated users cannot authenticate; their past records remain intact. |

## 9.1 Data validation

- Trim unnecessary whitespace and validate required fields on both client and server.
- Use numeric decimal storage for money; never use floating-point arithmetic for financial totals.
- Reject negative expense values and invalid dates.
- Validate uploaded file type, size and content; store uploads outside public executable paths.
- Protect against SQL injection, cross-site scripting and cross-site request forgery.
- Use database transactions for multi-step operations such as saving a visit and its service lines.

# 10. Data Model and Database Structure

The following logical schema is a recommended starting point. Exact field types and indexes should be finalised during implementation.

| Table | Key fields / purpose |
|---|---|
| users | id, name, email/username, password_hash, role_key, status, last_login_at, created_at. |
| patients | id, patient_number, full_name, sex, date_of_birth, phone, address, emergency_contact, medical_history, status, created_by, timestamps. |
| visits | id, visit_reference, patient_id, visit_datetime, chief_complaint, assessment_notes, treatment_notes, plan_notes, follow_up_date, status, recorded_by, timestamps. |
| service_categories | id, name, description, is_active, sort_order, created_by, timestamps. |
| services | id, service_code, category_id, name, description, standard_price, duration_minutes, requires_notes, is_active, sort_order, timestamps. |
| visit_services | id, visit_id, service_id nullable, service_name_snapshot, service_code_snapshot, price_snapshot, notes, timestamps. |
| expense_categories | id, name, description, is_active, sort_order, timestamps. |

| Table | Key fields / purpose |
|---|---|
| expenses | id, expense_reference, title, category_id nullable, category_name_snapshot, amount, expense_date, description, payee, payment_method, receipt_path, status, recorded_by, reviewed_by, reviewed_at, void_reason, timestamps. |
| clinic_settings | id, setting_key, setting_value, value_type, updated_by, updated_at. |
| audit_logs | id, user_id, action, entity_type, entity_id, old_values, new_values, ip_address, user_agent, created_at. |
| password_reset_tokens | email/username reference, token_hash, expires_at, created_at. |
| sessions | session_id, user_id, ip_address, user_agent, last_activity. |

### 10.1 Relationships

- patients 1-to-many visits.
- visits 1-to-many visit_services.
- service_categories 1-to-many services.
- expenses belong to one expense category (category may be nullable only for legacy migration).
- users 1-to-many patients created, visits recorded and expenses recorded.
- users 1-to-many audit_logs.

### 10.2 Important database decisions

- Use primary keys and foreign keys; add indexes on patient_number, full_name, phone, visit_datetime, expense_date, category_id and status.
- Use DECIMAL(14,2) or equivalent for monetary values.
- Store timestamps in a consistent standard (prefer UTC in storage) and render using Africa/Dar_es_Salaam.
- Use soft deletes only where justified; for clinical and financial records prefer explicit status and archive/void fields.
- Store historical snapshots for service names and prices so later configuration changes do not rewrite old records.
- Encrypt sensitive backups and protect receipt files with authenticated access.

## 11. Reports, Dashboards and Exports

### 11.1 Dashboard indicators

| Indicator | Definition |
|---|---|
| Total active patients | Count of patients with Active status. |
| New patients | Patients registered in selected date range. |
| Total visits | Visits created in selected date range, excluding voided visits. |
| Service activity | Visit-service count grouped by service. |
| Expenses recorded | Expense total for selected period, with clear distinction between submitted and approved if approval mode is on. |
| Expense by category | Sum of qualifying expenses grouped by category. |
| Recent activity | Latest patient, visit and expense records the current user is allowed to see. |

### 11.2 Report filters

- Date from / date to.

- Patient number or patient name (where relevant).
- Service and service category.
- Expense category and status.
- Recorded by / staff member.
- Report status and export format.

### 11.3 Report presentation

Reports should show clinic identity, report title, selected period, generation timestamp, generated-by user, totals, page numbers and optional signature lines. Patient reports should be treated as confidential and should not be exposed through public URLs.

## 12. Security, Privacy and Auditability

### 12.1 Security controls

- Enforce authorization on every server endpoint and data query.
- Hash passwords using a modern password hashing algorithm supported by the framework.
- Use HTTPS only in production.
- Use secure, HttpOnly and SameSite session cookies; protect against CSRF.
- Rate-limit login, password reset and sensitive endpoints.
- Validate and sanitise all user input; escape output.
- Restrict uploads by file extension, MIME type, size and malware scanning where available.
- Keep application secrets and database credentials outside source control.
- Apply least privilege to database and server accounts.
- Keep framework, dependencies and operating system patched.

### 12.2 Patient privacy

Patient data is confidential. Collect only information required for clinic operations and patient care. Restrict access to authorised clinic users, avoid sharing patient exports through public links, and establish a clinic-approved retention and disclosure policy consistent with applicable Tanzanian privacy and health-sector requirements. The clinic should confirm its legal obligations and obtain any required patient notices/consents before production use.

### 12.3 Audit log

Audit events should include login success/failure, patient create/update/archive, visit create/update/complete/void, service and category changes, expense create/update/approve/reject/void, user create/deactivate, settings changes, report exports and backup/restore actions.

Audit logs should be append-only for normal application users. Administrator should be able to view and filter them but should not be able to silently edit past audit entries.

### 12.4 Sensitive data safeguards

- Do not include patient clinical notes in routine system emails or notification previews.
- Mask sensitive information in list views where full detail is not needed.
- Automatically log out inactive sessions according to configured timeout.
- Do not expose storage paths or direct public links to patient documents.
- Maintain a documented incident response and breach escalation procedure.

# 13. User Interface and Experience Requirements

## 13.1 Visual direction

Use a clean, calm healthcare interface: predominantly white background, restrained navy/blue accents, clear typography, consistent spacing, simple cards and readable tables. Avoid dense dashboards, excessive colours, decorative gradients and unnecessary animation.

## 13.2 Layout

- Desktop: compact left sidebar, top header, main content area.
- Mobile: collapsible navigation, full-width forms, large touch targets and stacked data cards.
- Forms: group related fields, clearly mark required fields and show inline validation.
- Tables: search, sort, pagination and date filters; keep key actions visible.
- Profiles: patient summary at top, visit history below, clear 'New Visit' action.
- Empty states: explain what is missing and provide one relevant action.

## 13.3 Accessibility

- Use readable contrast and keyboard-accessible controls.
- Associate labels with form inputs.
- Do not rely on colour alone to communicate status.
- Provide clear error messages and confirmation for destructive actions.
- Support common modern browsers and responsive viewport sizes.

# 14. Technical Architecture and Recommended Stack

Recommended implementation for a small clinic: a Laravel modular application with server-rendered Blade pages, Tailwind CSS or Bootstrap, and MySQL/MariaDB. This avoids unnecessary frontend/backend complexity while providing a maintainable foundation.

| Layer | Recommendation | Notes |
|---|---|---|
| Application | Laravel (current supported stable release) | Authentication, validation, routing, policies, queues if needed. |
| UI | Blade + Tailwind CSS or Bootstrap | Choose one styling system and keep components consistent. |
| Database | MySQL 8+ / supported MariaDB | Relational integrity, indexes and transactions. |
| Authentication | Laravel session authentication | Sanctum is unnecessary unless a separate API/mobile client is introduced. |
| Authorization | Fixed role keys + policies/middleware | ADMIN and CLINIC_STAFF. |
| PDF | Laravel-compatible PDF library | Generate patient and management reports. |
| Files | Private local storage or private object storage | Receipts and optional attachments. |
| Hosting | Ubuntu VPS with HTTPS | Nginx or Apache; scheduled backups and monitoring. |

## 14.1 Application structure

Keep modules logically separated without overengineering. Suggested areas: Authentication, Patients, Visits, Services, Expenses, Reports, Settings, Users and Audit. Each area may contain controllers, request validators, policies, services and views.

### 14.2 Architecture flow

Browser → HTTPS web server → Laravel routes/middleware → controller → validation/policy → application service → database transaction → audit event → response/view/PDF. Business rules belong on the server, not only in JavaScript.

### 14.3 Environment configuration

- APP_ENV, APP_KEY, APP_DEBUG=false in production.
- Database credentials and mail credentials in protected environment variables.
- Configure timezone and locale deliberately.
- Use separate development, staging and production environments.
- Never commit .env files, secrets, database dumps or patient data to source control.

## 15. API and Integration Design

Version 1 can operate as a server-rendered web application and does not require a public API. If API endpoints are introduced for future mobile access, use authenticated, versioned routes and the same permission policies.

| Example route | Method | Purpose / access |
|---|---|---|
| /login | POST | Authenticate user. |
| /patients | GET / POST | List or register patients; authenticated users. |
| /patients/{id} | GET / PUT | View or update patient; policy controlled. |
| /patients/{id}/visits | GET / POST | View history or create visit. |
| /visits/{id} | GET / PUT | View/update visit; completion rules apply. |
| /admin/services | GET / POST | Admin-only service catalogue. |
| /admin/services/{id} | PUT / PATCH | Admin-only service updates. |
| /expenses | GET / POST | List or record expenses. |
| /expenses/{id} | GET / PUT | View/update expense; ownership/role rules apply. |
| /admin/reports/* | GET | Admin reports and exports; selected staff reports if enabled. |
| /admin/settings/* | GET / PUT | Admin-only configuration. |

### 15.1 Integrations

No third-party integration is required for the first release. Optional later integrations may include email/SMS notifications, cloud backup, accounting export or a patient portal. Each integration must be explicitly configured by the Administrator or technical operator, with credentials stored securely.

# 16. Non-Functional Requirements

| Area | Requirement |
|---|---|
| Performance | Common screens should load within approximately 2 seconds under normal clinic usage and reasonable network conditions. |
| Availability | Target 99% monthly availability excluding planned maintenance, subject to hosting capability. |
| Scalability | Support the clinic's expected users and records; design indexes and pagination to avoid full-table loading. |
| Reliability | Use transactions for related writes and show clear save/failure feedback. |
| Maintainability | Use readable code, migrations, automated tests and documented deployment steps. |
| Compatibility | Support current Chrome, Edge, Firefox and Safari versions. |
| Usability | A new staff member should be able to perform basic patient and expense tasks after brief training. |
| Security | HTTPS, role checks, password hashing, input validation, backups and audit trails. |
| Data portability | Allow authorised export of relevant records to PDF/CSV. |
| Localization | Default currency TZS and timezone Africa/Dar_es_Salaam; labels should be easy to localise. |

# 17. Backup, Deployment and Operations

## 17.1 Deployment checklist

- Provision supported Ubuntu server, web server, PHP version/extensions and MySQL/MariaDB.
- Configure DNS, HTTPS certificate and firewall.
- Create least-privilege database and application accounts.
- Deploy application code and run database migrations.
- Set production environment variables and disable debug mode.
- Set correct storage permissions and private upload storage.
- Configure scheduler/cron for maintenance and backup jobs.
- Create first Administrator account securely.
- Run smoke tests for login, patient registration, visit creation, expense recording and report export.

## 17.2 Backup policy

Recommended baseline: daily encrypted database backup, daily backup of private uploaded receipts/documents, and a weekly off-server copy. Retain a practical rotation such as 7 daily, 4 weekly and 3 monthly backups, subject to clinic policy and storage capacity. Test restoration periodically; a backup that has never been restored is not proven.

## 17.3 Operational responsibilities

| Responsibility | Owner |
|---|---|
| User account and clinic configuration | Administrator |
| Daily patient/visit/expense entry | Clinic Staff |
| Review records and management reports | Clinic Administrator / management |
| Server patching, deployment and technical backup monitoring | Assigned technical operator |
| Clinical correctness and retention policy | Clinic management / authorised clinical lead |

# 18. Testing and Acceptance Criteria

## 18.1 Minimum test scenarios

- Valid and invalid login; deactivated account blocked; session timeout works.
- Admin can create Clinic Staff account; staff cannot access user-management URLs.
- Staff can register a patient; duplicate warning appears for matching details.
- Patient number is unique and generated correctly.
- Staff can create a visit and attach active services.
- Inactive service cannot be selected for a new visit but appears in historical visit detail.
- Admin can create, edit, price, deactivate and reorder services without code changes.
- Staff can record an expense with valid category and amount.
- Invalid/negative amount is rejected; missing category is rejected where required.
- Admin can manage expense categories without code changes.
- Approval mode, when enabled, correctly separates submitted and approved totals.
- Reports filter correctly by date and category and export to PDF/CSV.
- Audit log captures important changes and identifies the actor.
- Unauthorised users cannot access protected routes or private attachments.
- Backup and restore procedure is successfully tested.

## 18.2 Acceptance criteria

The system is ready for clinic acceptance when all critical tests pass, the two fixed roles enforce the agreed permissions, all configured service and expense options are editable through the Administrator interface, patient and visit histories are accurate, expenses reconcile to their source records, reports export correctly, and the clinic representative can complete common tasks without developer support.

## 18.3 User acceptance test (UAT)

The clinic representative should test with fictional or approved test data before real patient data is entered. UAT should include a new patient, returning patient, multiple visits, service configuration change, expense entry, optional expense approval, monthly report and user deactivation.

# 19. Implementation Phases and Deliverables

| Phase | Work | Deliverable |
|---|---|---|
| 1. Discovery & confirmation | Confirm clinic identity, service list, user details, required fields, expense categories and report formats. | Signed-off configuration checklist. |
| 2. Foundation | Project setup, database, authentication, fixed roles, layout and audit foundation. | Working login and role-based dashboard shell. |
| 3. Patient records | Patient registration, search, profile, archive and history. | Patient register module. |
| 4. Visits & services | Visit workflow, clinical notes and configurable service catalogue. | Patient visit records and admin service management. |
| 5. Expenses | Expense records, categories, optional approval and attachments. | Expense register and management. |
| 6. Reports & settings | Dashboard metrics, PDF/CSV exports, clinic settings and user management. | Reports and configuration interface. |
| 7. Quality & launch | Security checks, UAT, backup restore test, training and production deployment. | Production release and handover pack. |

## 19.1 Handover deliverables

- Production application and source code repository.
- Database migrations and seed data for fixed roles and initial admin.
- Administrator user guide and Clinic Staff quick guide.
- Deployment and backup/restore instructions.
- Test report and UAT sign-off.
- List of configured services, categories and clinic settings.
- Known limitations and future enhancement backlog.

# 20. Risks, Assumptions and Decisions to Confirm

| Item | Current assumption / decision needed |
|---|---|
| Clinic identity | Final clinic name, logo, address and contacts must be supplied. |
| Service catalogue | Administrator manages all service names, descriptions, categories, prices and active status. |
| Service pricing | Confirm whether prices are informational only or whether the clinic will record patient payments in a later phase. |
| Patient payments | Not included in Version 1 unless explicitly approved. Expenses are included. |
| Clinical record responsibility | Clinic must identify which staff are authorised to enter or amend clinical notes. |
| Expense approval | Optional setting; simple record-only mode is the default. |
| Staff permissions | Two fixed roles only. Confirm whether Clinic Staff may view all patient records or only records they create. |
| Data protection | Clinic management must confirm applicable privacy, retention, consent and disclosure requirements. |
| Hosting | Confirm VPS provider, domain, backup destination and responsible technical operator. |
| Languages | English-first implementation; Kiswahili labels can be added if required. |

**Important scope note: this specification does not include patient payment collection, invoicing, cashbook reconciliation or profit accounting. If management wants income-versus-expense reporting, a Patient Payments module must be approved and specified separately so that financial totals are not misleading.**

# Appendix A – Suggested Screen Inventory

| Screen | Key content / actions |
|---|---|
| Login | Clinic logo/name, username/email, password, sign in, forgot password. |
| Dashboard | KPI cards, date filter, recent activity, expense category chart, visit trend. |
| Patient list | Search, filters, patient number, name, phone, registration date, status, Add Patient. |
| Patient form | Required demographic details, optional fields controlled by settings, save/cancel. |
| Patient profile | Patient summary, edit action, visit timeline, New Visit, print/export if permitted. |
| Visit form | Patient, date/time, complaint, assessment, services, treatment notes, plan, follow-up, save/complete. |
| Visit detail | Visit reference, patient, selected services, notes, recorded by, status and print. |
| Service catalogue | Search, category filter, Add Service, edit, activate/deactivate, reorder. |
| Expense list | Search, date range, category, status, amount, recorded by, Add Expense. |
| Expense form | Title, category, amount, date, description, payee, method, receipt upload. |
| Reports | Report type, filters, preview, totals, PDF/CSV export. |
| Users | User list, create, role fixed to Clinic Staff, reset password, deactivate. |
| Settings | Clinic profile, regional settings, patient/visit numbering, optional fields, expense mode, reports. |
| Audit log | Date range, actor, action, entity, details; Admin only. |

# Appendix B – Example Configuration Catalogue

## B.1 Example service categories

- Assessment
- Physical rehabilitation
- Electrotherapy
- Manual therapy
- Specialised rehabilitation
- Home-based care
- Other

## B.2 Example services

- Initial Physiotherapy Assessment
- Follow-up Assessment
- Exercise Therapy
- Manual Therapy
- Electrotherapy
- Sports Injury Rehabilitation
- Neurological Rehabilitation
- Paediatric Physiotherapy
- Orthopaedic Rehabilitation

- Occupational Therapy
- Massage Therapy
- Home-based Physiotherapy

### B.3 Example expense categories

- Medical Supplies
- Equipment Maintenance
- Electricity
- Water
- Rent
- Transport
- Staff Welfare
- Cleaning
- Internet and Communication
- Other Expenses

### B.4 Example payment method options

- Cash
- Bank Transfer
- Mobile Money
- Card
- Other

All lists in this appendix are starter examples only. The Administrator must be able to create, edit, deactivate and reorder the clinic's actual options.

## Appendix C – Glossary

| Term | Meaning |
|---|---|
| Patient | A person registered with the clinic. |
| Visit / Session | A single attendance or treatment encounter for a patient. |
| Service | A physiotherapy or related service offered by the clinic. |
| Expense | A cost recorded by the clinic. |
| Administrator | The fixed full-access system role. |
| Clinic Staff | The fixed limited operational role. |
| Archive | Mark a record inactive while preserving its history. |
| Void | Mark a transaction or record as invalid while preserving the audit trail. |
| Audit log | A chronological record of important user and system actions. |
| Configuration | Clinic-managed settings and catalogue data editable through the interface. |

## END OF DOCUMENT

This document is the implementation baseline. Before development begins, the clinic should confirm the outstanding decisions in Section 20 and provide its approved service catalogue, clinic profile and initial Administrator details.